Day 29: SOC Incident Report

INC-20260929-001: Repeated Failed Logons Against Local Administrator Account CyberAmy

SOC Internship - TriosCyber

Field	Details
Intern Name	Amrita Pathak
Date	1 October 2026
Internship Track	SOC (Security Operations Center)
Assigned Task	Create a concise SOC incident report based on one alert investigated during the month. Include summary, affected asset, timeline, evidence, severity, analysis, actions taken and escalation/recommendation. (Tools: Wazuh evidence, spreadsheet/document)
Status of this Report	**Practical. This report consolidates a real alert investigated during the month: the repeated authentication failures generated and triaged in Day 25, collected and hash-sealed as case INC-20260929-001 in Day 26, and mapped to MITRE ATT&CK in Day 27. All facts come from that sealed evidence. The detection is described against Wazuh's real rule 60204; no live Wazuh alert exists because no Wazuh manager is deployed in this lab (see Days 17-20).**

Table of Contents

Table of Contents 2
Key Terms 4
Important Note on This Report 4
1. Incident Summary 5
1.1 What an Incident Summary Is 5
1.2 Summary of This Incident 5
2. Affected Asset 6
2.1 What an Affected Asset Is 6
2.2 Why Identifying It Matters 6
2.3 The Affected Asset in This Incident 7
3. Timeline 7
3.1 What an Incident Timeline Is 7
3.2 Why the Timeline Matters 7
3.3 Timeline of This Incident 8
4. Evidence 9
4.1 What Evidence Means in a SOC Report 9
4.2 Why Evidence Quality Matters 9
4.3 Evidence in This Incident 10
5. Severity 12
5.1 What Severity Is 12
5.2 Why Severity Is Assessed Twice 12
5.3 Severity Scale Used 13
5.4 Initial Severity: Medium 13
5.5 Final Severity: Low (Benign True Positive) 13
6. Analysis 14
6.1 What Analysis Means in an Incident Report 14
6.2 Was This a Brute-Force Pattern? 14
6.3 Where Did the Attempts Come From? 14
6.4 Did a Guess Succeed, and Who Logged On? 14
6.5 Were Defenses Effective? 16
6.6 Conclusion of Analysis 17

7. Actions Taken 17
7.1 What This Section Records 17
7.2 Why It Matters 17
7.3 Actions Taken in This Incident 18
8. Escalation and Recommendations 19
8.1 What Escalation Is and Why It Matters 19
8.2 Escalation Decision 19
8.3 Recommendations 19
8.4 Recommendations Summary 21
9. Conclusion 22
References 22

Key Terms

- **Incident Report:** The single document that records an investigated alert from detection to closure, written so a manager can understand it quickly and an auditor can trace every statement to evidence.
- **Alert vs. Incident:** An alert is a signal that a detection rule fired. It becomes an incident when investigation shows a real or potential security event that needs handling. Many alerts are closed without ever becoming incidents; this report uses the term incident report because that is the standard SOC document name.
- **Severity:** How serious an alert or incident is, based on its potential impact and how likely it is to be malicious. Severity is assigned when an alert arrives and revised after investigation.
- **Benign True Positive:** A detection that fired correctly, because the activity really matched the rule, but which investigation shows was not malicious.
- **Escalation:** Passing a case to a higher tier (for example L2 analysts or the incident response team) because it needs more expertise, authority or urgency than the current analyst has.
- **Containment:** Actions that stop an incident from spreading or causing further harm, such as disabling an account or isolating a host. Not needed when an alert is confirmed benign.
- **Chain of Custody:** The record of who collected and handled each item of evidence, when, and how, so its integrity can be defended.

Important Note on This Report

The alert in this report was produced by a controlled, authorized self-test, so its outcome is known in advance. The report is nevertheless written exactly as it would be for a genuine alert: the initial severity reflects what the analyst knew when the alert arrived, and the final verdict is reached only from evidence. Times are India Standard Time (UTC+05:30) unless marked UTC. As is standard for SOC incident reports, the document opens with the incident summary rather than an objective: the incident itself is the reason the report exists.

1. Incident Summary

1.1 What an Incident Summary Is

The incident summary, often called the executive summary, is the first and most-read part of any incident report. It answers four questions in a few sentences: what happened, what it affected, how serious it turned out to be, and what state the case is in now. Managers, clients and auditors frequently read only this section, so it must stand on its own without the rest of the report.

A good summary states facts, not impressions. Compare "suspicious login activity was detected" with "eight failed logons against the local administrator account CyberAmy between 13:07:33 and 13:11:19, followed by a successful logon by the account owner". The second tells the reader exactly what happened and can be checked against evidence.

1.2 Summary of This Incident

Incident ID	INC-20260929-001
Title	Repeated failed interactive logons against local administrator account CyberAmy
Detection	8 x Event ID 4625 in 226 seconds; meets Wazuh rule 60204 "Multiple Windows Logon Failures" (level 10)
MITRE ATT&CK	Credential Access (TA0006) / Brute Force: Password Guessing (T1110.001)
Initial severity	Medium
Final severity	Low (benign true positive)
Status	Closed
Escalated	No (rationale in Section 8)

On 29 September 2026, between 13:07:33 and 13:11:19 IST, eight failed logons were recorded against the local administrator account CyberAmy on the Windows endpoint DESKTOP-AUHDFVM, followed by a successful logon at 13:12:10. The pattern meets Wazuh's brute-force correlation threshold and maps to MITRE ATT&CK T1110.001 Password Guessing.

Investigation established that the attempts were made at the machine's own console against a valid user name, and that the successful logon was the account owner. The activity was an

authorized, controlled test. The alert is a benign true positive; no containment was required and the case is closed. The investigation identified two configuration gaps on the endpoint, no minimum password length and no password history, which are carried forward as recommendations.

2. Affected Asset

2.1 What an Affected Asset Is

An asset is anything of value to an organization that an incident can touch: a computer, server, user account, application, database, or the data inside them. The affected asset in an incident is whatever the activity was aimed at or actually reached. In identity-based attacks, there are usually two affected assets: the device (where it happened) and the account (what was targeted).

For example, if an attacker guesses the password of a payroll clerk's account on a finance laptop, the affected assets are the laptop and the clerk's account, and indirectly the payroll data the account can reach.

2.2 Why Identifying It Matters

Identifying the affected asset precisely is one of the first things a SOC analyst does, because almost every later decision depends on it:

- **Impact**: the same alert means very different things on a test VM, a domain controller or a database holding customer data. Asset value drives severity.
- **Privilege**: an administrator account can install software, create accounts, disable security tools and read every file. Compromising it is far more damaging than compromising a standard user.
- **Scope**: knowing the exact host and account tells the analyst where to look for further activity, and which other systems the account could reach.
- **Response**: containment actions such as isolating a host or disabling an account can only be targeted correctly if the asset is identified correctly.
- **Ownership**: every asset has an owner who must be informed and who can confirm whether activity was expected, as happened in this case.

2.3 The Affected Asset in This Incident

Attribute	Value	Source
Hostname	DESKTOP-AUHDFVM	systeminfo.txt; Event ID 4625 records
Asset type	Windows workstation, virtual machine in a lab environment	net accounts (Computer role: WORKSTATION)
Time zone	India Standard Time (UTC+05:30)	timezone.txt
Affected account	CyberAmy	Event ID 4625 / 4624 records
Account privilege	Member of local Administrators	local_admins.txt
Account status	Not locked; lockout threshold 10 not reached	lockout_policy.txt
Network exposure	Attempts came from the local console (127.0.0.1); no remote source	Event ID 4625 IpAddress field

Two assets were involved: the workstation DESKTOP-AUHDFVM and the account CyberAmy. The account is the more important of the two, because it is a local administrator. Had a guess succeeded for an unauthorized person, they would have gained full control of the workstation: the ability to install software, create new accounts, change security settings and read or delete any local data.

This is the main reason the alert was initially treated as Medium rather than Low (Section 5). Against that, the workstation is a lab VM holding no business data, and the attempts came from its own console rather than the network, which limits the realistic impact. Recording both sides is what makes the severity decision defensible.

3. Timeline

3.1 What an Incident Timeline Is

A timeline is the ordered sequence of everything that happened in an incident, from the first suspicious event to the closure of the case, each with a precise time and a pointer to its evidence. It covers two kinds of events: what the activity did (the failures and the logon), and what the SOC did in response (triage, collection, sealing).

3.2 Why the Timeline Matters

- **It reveals the story**: the order of events shows cause and effect, for example that the successful logon came after the failures, not before.

- **It exposes patterns**: the intervals between attempts (23 to 40 seconds here) suggest a person typing rather than an automated tool, which can make many attempts per second.
- **It measures response**: the gap between the activity and detection, and between detection and verdict, shows how well the SOC performed.
- **It must be in one time zone**: mixing local time and UTC is one of the most common evidence errors. This timeline uses IST throughout, with UTC conversions recorded in the Day 26 case.
- **It must be honest**: where an exact time was not recorded, the timeline says so rather than inventing one.

3.3 Timeline of This Incident

29 September 2026, IST:

Time	Event	Evidence
Before 13:07	Account lockout policy checked: threshold 10, duration 10 min	SS01; lockout_policy.txt
13:07:33	First failed logon (Event ID 4625), CyberAmy, Logon Type 2	Security_INC_window.evtx
13:08:08 to 13:10:34	Failed logons 2 to 7, at 23 to 40 second intervals	Security_INC_window.evtx
13:11:19	Eighth failed logon: 8 failures in 226 seconds. Wazuh rule 60204 conditions met (8 within 240s)	Security_INC_window.evtx
13:12:10	Successful logon (two linked Event ID 4624s, UAC split token)	Security_INC_window.evtx; SS06
Afternoon	Triage in Event Viewer: failures counted, successful logon attributed via New Logon field (Day 25)	SS02 to SS04
20:53	Case folder INC-20260929-001 created; time zone confirmed (Day 26)	Day 26 report, Figure 1
Evening	Security log exported (window and full), parsed copy produced, endpoint state captured	02_Logs_Raw; 03_Logs_Parsed; 04_Endpoint_Info
Before 22:59	Case notes and chain of custody written; all 18 evidence files SHA-256 hashed (case sealed)	hash_manifest.csv
Late evening	Behavior mapped to MITRE ATT&CK T1110.001 (Day 27)	Day 27 report

Reading the timeline: the attempts were spaced 23 to 40 seconds apart, a pace consistent with a person typing at the logon screen rather than an automated tool. On a live Wazuh deployment, rule 60204 would have fired at 13:11:19, the moment of the eighth failure, before the lockout threshold of 10 was reached. The benign verdict was reached during same-day triage, and the case was documented and sealed the same evening, so the evidence was preserved within hours of the activity.

4. Evidence

4.1 What Evidence Means in a SOC Report

Evidence is the recorded data that proves each statement in the report. In a SOC it is usually machine-generated: event logs, alerts, network records and system state. Evidence falls into two kinds. Primary evidence is what the system itself recorded, such as the exported .evtx log files. Supporting evidence, such as screenshots, shows what the analyst saw but cannot be re-examined or re-filtered the way a log file can.

4.2 Why Evidence Quality Matters

- **Every conclusion must be traceable**: a reviewer should be able to point at any sentence in this report and find the file that proves it.
- **Integrity must be provable**: SHA-256 hashes recorded when the case was sealed show that no file has been altered since.
- **Handling must be recorded**: the chain of custody shows who collected what, when and how, including the three handling issues that occurred during collection.
- **Evidence can disappear**: Windows overwrites old event log entries once a log is full, so evidence that is not exported promptly may be lost.
- **Cases can be reopened**: if new information emerges later, a sealed evidence package lets someone else re-examine the case without relying on memory.

4.3 Evidence in This Incident

All evidence is held in the sealed case folder C:\Incidents\INC-20260929-001 on the affected endpoint, collected as described in the Day 26 report.

Item	Location in case	Type
Security log, incident window (4624/4625)	02_Logs_Raw\Security_INC_window.evtx	Primary
Security log, full export	02_Logs_Raw\Security_full.evtx	Primary
Parsed events (time, user, logon type, source, status)	03_Logs_Parsed\INC_window_parsed.csv	Working copy
System, network, account, admin group, lockout policy, time zone, collection time	04_Endpoint_Info (8 files)	Context
Screenshots SS01 to SS06	01_Screenshots	Supporting
Wazuh status note	05_Wazuh\wazuh_status_note.txt	Gap record
Case summary, chain of custody, inventory, hash manifest	00_Case_Notes	Case records

The two most important evidence items are shown below: the parsed incident window, which supplies almost every fact in this report, and the hash manifest, which proves the evidence has not changed.

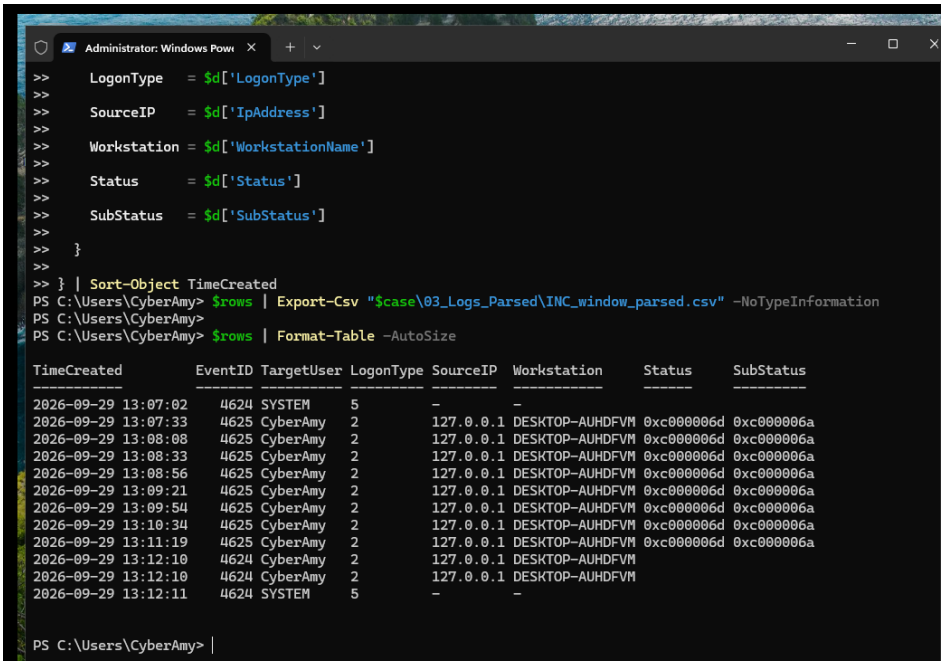


Figure 1. Key fields of every logon event in the incident window, parsed from the sealed evidence file (case file SS05).

What this screenshot shows:

- This table was produced by reading the exported evidence file Security_INC_window.evtx, not the live log, so it reflects exactly what is sealed in the case.
- Rows 2 to 9 are the eight failed logons (Event ID 4625) for CyberAmy from 13:07:33 to 13:11:19: Logon Type 2 (interactive), source IP 127.0.0.1, workstation DESKTOP-AUHDFVM.
- Every failure carries Status 0xc000006d and SubStatus 0xc000006a: the user name was valid and the password wrong.
- The two rows at 13:12:10 are the successful logon (Event ID 4624). The first and last rows are SYSTEM with Logon Type 5 (Service), which are Windows services and not part of the incident.
- This single table supplies the incident's timestamps, affected account, source details and failure reason.

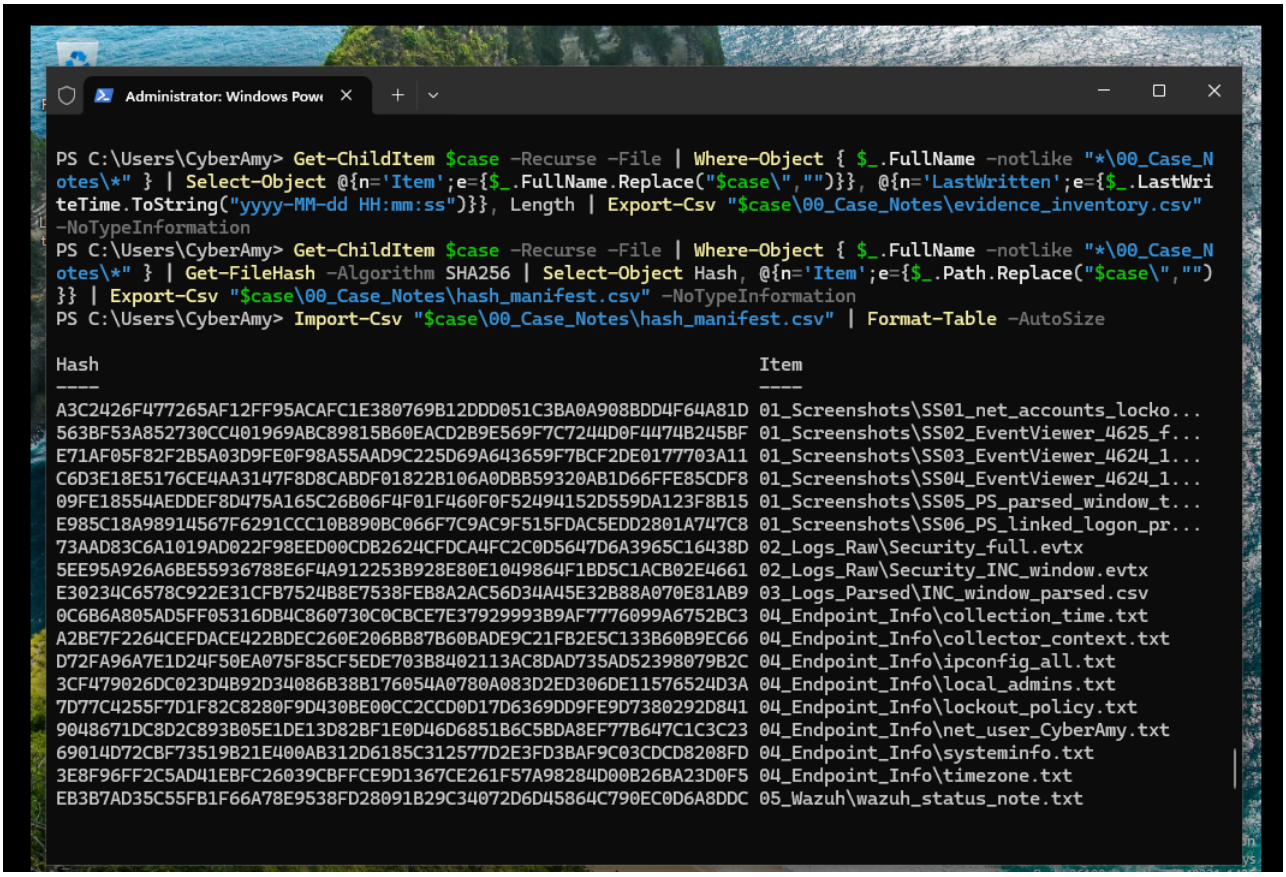


Figure 2. The hash manifest sealing all 18 evidence files (00_Case_Notes\hash_manifest.csv).

What this screenshot shows:

- The upper part shows the commands that wrote the evidence inventory and calculated a SHA-256 hash for every file in folders 01 to 05.
- The table lists 18 rows, one per evidence file, each with its 64-character SHA-256 fingerprint.
- Any reviewer can re-hash the files and compare: matching values prove the evidence behind this report has not changed since it was sealed.

5. Severity

5.1 What Severity Is

Severity is a rating of how serious an alert or incident is. It combines two things: impact (how much damage it could do, which depends largely on the affected asset) and likelihood (how probable it is that the activity is malicious). Severity decides how fast a case is handled, who handles it, and who must be told.

Detection tools assign their own levels. Wazuh, for example, rates rules from 0 to 15. A tool's level is an input to severity, not the final answer: the tool sees one event pattern, while the analyst also knows the asset, the account and the context.

5.2 Why Severity Is Assessed Twice

When an alert arrives, the analyst knows very little, so the initial severity must assume the activity could be malicious. After investigation, the evidence either confirms or removes that possibility, and the final severity is revised. Recording both shows the reader that the alert was taken seriously at first and that the final rating was earned through evidence, not assumed. Downgrading too early is how real attacks are missed; never downgrading is how SOCs drown in false alarms.

5.3 Severity Scale Used

The following four-level scale is the convention used in this report. Organizations define their own scales, but most follow this pattern.

Severity	Meaning	Typical response
Critical	Confirmed compromise with significant impact, or active attack in progress	Immediate escalation to incident response
High	Likely malicious activity against an important asset	Escalate to L2 promptly
Medium	Possibly malicious; needs investigation before a verdict	L1 investigates; escalate if not resolved
Low	Investigated and benign, or minimal impact	Document and close

5.4 Initial Severity: Medium

- Wazuh assigns rule 60204 level 10, which Wazuh's rule classification describes as "Multiple user generated errors... These may indicate an attack or simply signal that a user has forgotten their credentials." The detection alone cannot distinguish the two.
- The targeted account is a local administrator, which raises potential impact (Section 2).
- The attempts used a valid user name, SubStatus 0xC000006A, which suggests a targeted attempt rather than random guessing.
- A successful logon followed the failures, so it had to be established whether a guess had succeeded.
- Against these, the attempts came from the local console only, with no remote source, which lowers the likelihood of an external attacker. This is why the rating was Medium rather than High.

5.5 Final Severity: Low (Benign True Positive)

- The successful logon was confirmed as the account owner: a single ordinary logon recorded as two linked UAC sessions (Figure 3).
- The activity was a documented, authorized self-test by the account owner (Day 25).
- No further suspicious activity followed; the account was not locked and no other accounts were targeted.
- The rule fired correctly, so this is a true positive, not a false positive; the activity was simply not malicious.

6. Analysis

6.1 What Analysis Means in an Incident Report

Analysis is where the analyst turns evidence into a conclusion. It answers the questions that decide the verdict: what kind of activity this was, where it came from, whether it succeeded, and whether defenses worked. Each answer must point to evidence, and each alternative explanation must be considered and ruled in or out. Analysis is the part of the report that separates an investigation from a description.

For this incident, four questions decided the verdict.

6.2 Was This a Brute-Force Pattern?

Yes. Eight failures against a single account in 226 seconds is a repetitive, iterative guessing pattern, not a single typing mistake. It meets Wazuh rule 60204 (8 failures from the same source IP within 240 seconds) and maps to MITRE ATT&CK Credential Access (TA0006), Brute Force: Password Guessing (T1110.001). Password Spraying (T1110.003) and Credential Stuffing (T1110.004) were ruled out because only one account was targeted and no breached credential pairs were involved.

6.3 Where Did the Attempts Come From?

All eight failures record Logon Type 2 (interactive) and source address 127.0.0.1, which Microsoft documents as meaning localhost. The attempts were therefore typed at the endpoint's own console, not sent over the network. A Remote Desktop attempt would have recorded Logon Type 10 and a remote address. This removes the scenario of an external attacker guessing passwords across the network, although physical or console access by an unauthorized person would still need to be ruled out, which the owner's confirmation did.

6.4 Did a Guess Succeed, and Who Logged On?

A successful logon followed at 13:12:10. It appears as two Event ID 4624 records that list each other as their linked logon, one with an elevated token (%%1842) and one without (%%1843). This is the UAC split token created whenever an administrator logs on interactively with User Account Control enabled. The New Logon field identifies CyberAmy. It is one logon by the account owner, not two separate logons.

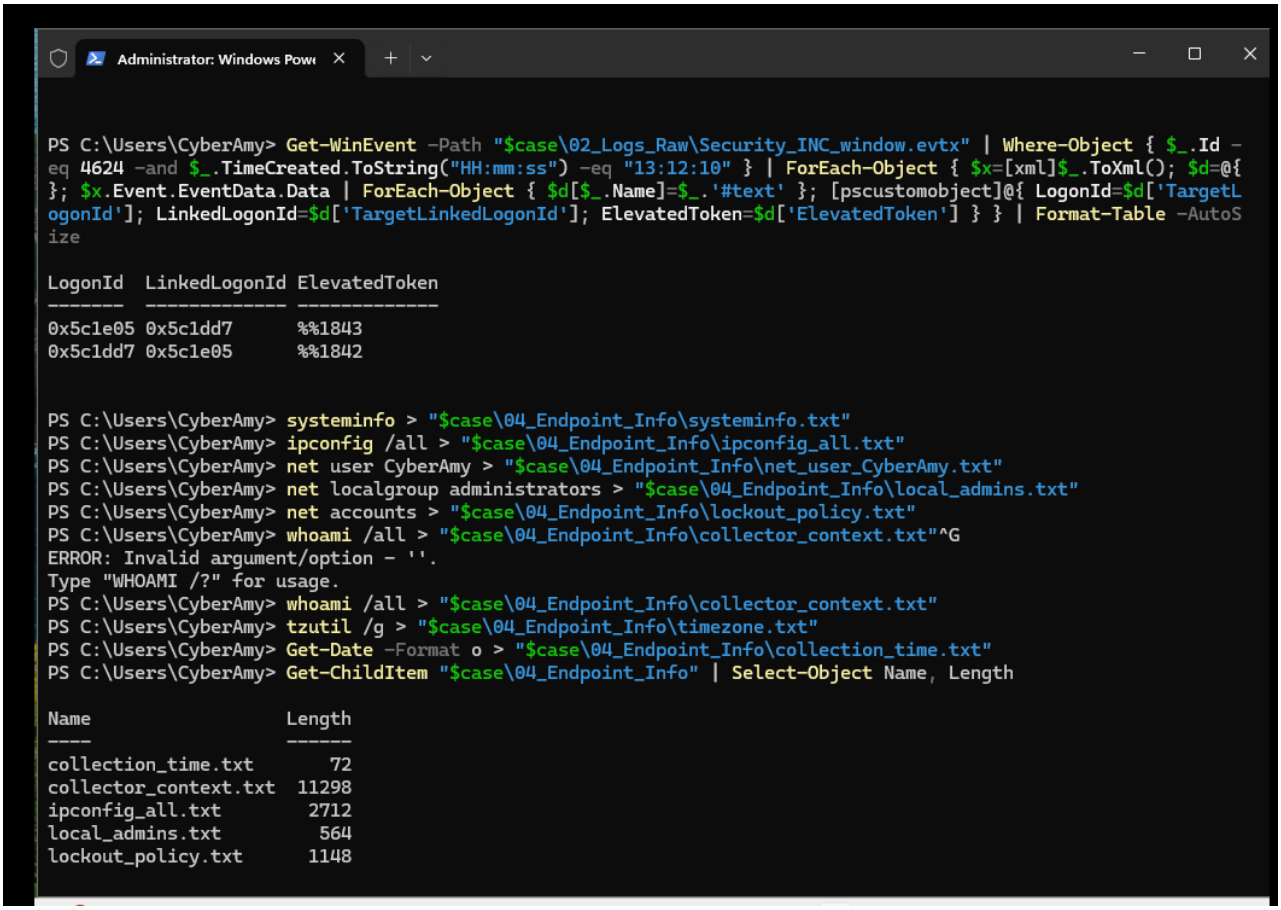


Figure 3. The two linked logon sessions at 13:12:10 (case file SS06).

What this screenshot shows:

- The table at the top was produced by reading only the 13:12:10 Event ID 4624 records from the sealed evidence file.
- LogonId 0x5c1e05 lists 0x5c1dd7 as its linked logon, and 0x5c1dd7 lists 0x5c1e05: the two sessions belong to one logon.
- One has ElevatedToken %%1843 (No) and the other %%1842 (Yes), the standard and administrator halves of a UAC split token.
- This proves the two 4624 events are a single administrator logon, removing the possibility that a second party also logged on. The commands below the table are the endpoint information captures from the Day 26 collection.

6.5 Were Defenses Effective?

Partly. The account lockout policy (threshold 10) was in place and sits above the detection threshold (8), so the SOC would be alerted before the account locked. However, the endpoint enforces no minimum password length and keeps no password history, which makes password guessing more likely to succeed in a real attack.

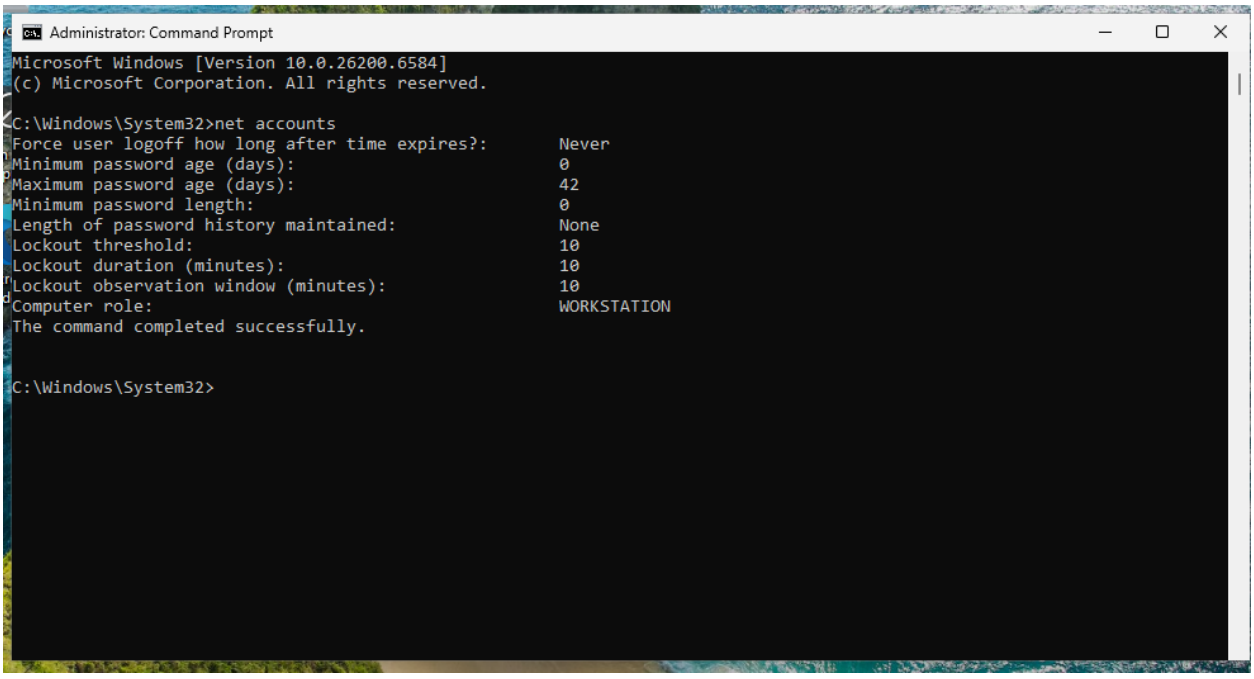


Figure 4. The endpoint's account policy from net accounts (case file SS01).

What this screenshot shows:

- Lockout threshold 10, duration 10 minutes, observation window 10 minutes: lockout is configured, and 8 failures did not trigger it.
- Minimum password length 0: no minimum length is enforced, a gap against MITRE mitigation M1027 Password Policies.
- Length of password history maintained: None: old passwords can be reused immediately.
- Maximum password age 42 days: passwords expire, which is configured.

6.6 Conclusion of Analysis

The alert was a correct detection of a password-guessing pattern. The source was the local console, the target was a valid administrator account, and the only successful logon was the account owner's. Combined with the documented test authorization, the evidence supports a verdict of benign true positive. The analysis also exposed real weaknesses in the endpoint's password policy, which are addressed in Section 8.

7. Actions Taken

7.1 What This Section Records

Actions taken is the factual record of everything the analyst did, in order. It covers triage, evidence collection and any response actions such as containment. It is written in the past tense and states only what was actually done, not what should be done (that belongs in recommendations).

7.2 Why It Matters

- Accountability: it shows the case was handled properly and in line with procedure.
- Reproducibility: another analyst can follow the same steps to check the work or continue it.
- Gaps become visible: if an expected step is missing (for example, no evidence preservation), reviewers can see it.
- Lessons learned: the record of what was done, and what went wrong during handling, improves future response.

7.3 Actions Taken in This Incident

#	Action	Outcome
1	Checked the account lockout policy before activity began	Confirmed threshold 10; test kept below it
2	Triaged the failures in Event Viewer: filtered Event ID 4625, counted and timed each attempt	8 failures in 226 seconds identified
3	Identified the successful logon and attributed it using the 4624 New Logon field	Logon at 13:12:10 attributed to CyberAmy
4	Assessed the pattern against Wazuh rule 60204	Threshold met (8 in 226s of 240s)
5	Created case INC-20260929-001 and normalized time zone to UTC for collection	Consistent timestamps
6	Exported the Security log with wevtutil (window and full) without modifying the original	Primary evidence preserved
7	Parsed the exported log and verified the split-token logon from LogonId and ElevatedToken fields	Two 4624s proven to be one logon
8	Captured endpoint state (system, network, account, admin group, policy, time zone, time)	Context preserved
9	Wrote case summary and chain of custody, recording three handling issues	Defensible record
10	Hashed all 18 evidence files with SHA-256	Case sealed
11	Mapped the behavior to MITRE ATT&CK	TA0006 / T1110.001
12	Closed the case as a benign true positive	No containment required

No containment actions (account disablement, password reset or host isolation) were taken, because the activity was confirmed as authorized. In a genuine incident with an unexplained successful logon after these failures, the CyberAmy account would have been disabled and its password reset, the host isolated from the network pending investigation, and activity after 13:12:10 examined for signs of misuse such as new accounts, new services or privilege changes.

8. Escalation and Recommendations

8.1 What Escalation Is and Why It Matters

Escalation is the decision to pass a case to a higher tier, such as L2 analysts, the incident response team or management, because it needs more expertise, authority or urgency than the current analyst has. An L1 analyst's core responsibility is to escalate the right cases quickly and not to escalate the rest. Escalating everything overwhelms senior staff; escalating too little lets real attacks progress.

8.2 Escalation Decision

Not escalated to L2 or incident response. Escalation is warranted when a case cannot be resolved at the current tier or shows signs of compromise. Here, the source, account owner, and authorization were all confirmed from evidence; no further suspicious activity followed, and no other assets were involved. The case is recorded and reported to the lab supervisor through this report.

Escalation would have been required if any of the following had been true:

- The successful logon could not be attributed to the account owner.
- The attempts came from a remote or unknown address.
- Other accounts or hosts showed the same pattern.
- Activity after the logon (new processes, new accounts, privilege changes) looked suspicious.

8.3 Recommendations

Recommendations are the forward-looking part of the report: changes that would reduce the chance of a similar incident succeeding, or improve how it is detected and handled next time. Each should come from a specific finding in the evidence, so it can be justified to whoever has to implement it.

Recommendation 1: Enforce a minimum password length

Finding: net accounts shows a minimum password length of 0 (Figure 4), so the endpoint accepts very short passwords, or none at all. Why it matters: password guessing, the technique observed here, succeeds most often against short and common passwords. MITRE lists Password Policies (M1027) as a mitigation for T1110.001, describing it as setting and enforcing secure password policies to reduce the likelihood of unauthorized access. Action: set a

minimum length in line with the organization's password policy through Local Security Policy or Group Policy, and require existing accounts to change to compliant passwords.

Recommendation 2: Enable password history

Finding: password history is set to None (Figure 4), so a user forced to change a password can immediately set it back to the old one. Why it matters: if an old password is ever exposed, it stays valid indefinitely through reuse, and periodic password expiry becomes meaningless. Action: configure password history so that a set number of previous passwords cannot be reused, in line with organizational policy.

Recommendation 3: Deploy the Wazuh manager and enroll this endpoint

Finding: no Wazuh manager is deployed in this lab (see Days 17-20), so rule 60204 could only be applied to the evidence after the fact. Why it matters: detection only protects an organization if it runs in real time. Live, this alert would have reached the SOC at 13:11:19, within seconds of the eighth failure, rather than being found by manual review. Action: deploy the Wazuh manager, enroll DESKTOP-AUHDFVM as an agent, and confirm with a controlled test that rule 60204 produces a live alert.

Recommendation 4: Consider multi-factor authentication for administrator logons

Finding: the administrator account is protected by a password alone. Why it matters: with multi-factor authentication, a correctly guessed password is no longer enough to log on. MITRE lists Multi-factor Authentication (M1032) as a mitigation for T1110.001, describing MFA as requiring at least two forms of verification before granting access. Action: evaluate MFA options for administrator logons on this class of endpoint, prioritizing accounts with administrative rights.

Recommendation 5: Use a separate analyst account for evidence collection

Finding: evidence was collected while logged on as CyberAmy, the account under investigation (recorded in collector_context.txt and the chain of custody). Why it matters: in a real incident, using the suspect account can alter its activity records, mix the analyst's actions into the evidence, and, if the account is compromised, expose the analyst's work to the attacker. Action: collect evidence with a dedicated analyst account. This was acceptable in the lab only because the analyst and account owner were the same person.

Recommendation 6: Forward Security logs centrally or increase log size

Finding: the evidence existed only on the endpoint itself until it was exported. Why it matters: Windows overwrites the oldest log entries once a log reaches its maximum size, and an attacker with administrator rights can clear local logs. Either would destroy evidence. Action: forward

Security logs to central storage, which a deployed Wazuh manager would provide, and size local logs so that several days of events are retained.

Recommendation 7: Record planned tests in advance

Finding: the benign verdict depended on confirming the activity was an authorized test. Why it matters: when tests are recorded beforehand (in a change or test record with the host, account and time window), the SOC can verify and close the resulting alert in minutes instead of investigating from scratch. Action: require planned security tests to be logged before they start.

Recommendation 8: Keep the lockout threshold above the detection threshold

Finding: the lockout threshold (10) is higher than the detection threshold (8). Why it matters: this ordering means the SOC is alerted while there is still time to act, before a legitimate user is locked out. If lockout came first, an attacker could lock users out (a denial of service) before the SOC ever saw an alert. Action: no change needed; preserve this ordering if either value is changed in future.

8.4 Recommendations Summary

#	Recommendation	Reason	Priority
1	Enforce a minimum password length	Currently 0; short passwords are easiest to guess (MITRE M1027)	High
2	Enable password history	Currently None; old passwords can be reused	Medium
3	Deploy the Wazuh manager and enroll this endpoint	Rule 60204 would alert live instead of after the fact	High
4	Consider MFA for administrator logons	A guessed password alone would no longer grant access (MITRE M1032)	Medium
5	Use a separate analyst account for evidence collection	Collection used the account under investigation	Medium
6	Forward Security logs centrally or increase log size	Local logs can be overwritten or cleared	Medium
7	Record planned tests in advance	Allows test alerts to be verified and closed quickly	Low
8	Keep lockout threshold above detection threshold	Already in place; SOC is alerted before users are locked out	Maintain

9. Conclusion

Case INC-20260929-001 was a correct detection of password guessing (MITRE T1110.001) against a local administrator account. It was triaged as Medium on arrival and closed as Low after evidence showed the attempts came from the local console, targeted the owner's account during an authorized test, and ended in a single legitimate logon. The evidence is preserved and hash-sealed, and the investigation produced practical recommendations, most importantly enforcing a minimum password length and deploying the Wazuh manager so that this detection operates live.

References

- Wazuh documentation, Rules classification: https://documentation.wazuh.com/current/user-manual/ruleset/rules/rules-classification.html
- Wazuh ruleset, 0580-win-security_rules.xml (rule 60204): https://raw.githubusercontent.com/wazuh/wazuh/master/ruleset/rules/0580-win-security_rules.xml
- MITRE ATT&CK, T1110.001 Password Guessing: https://attack.mitre.org/techniques/T1110/001/
- MITRE ATT&CK, M1027 Password Policies: https://attack.mitre.org/mitigations/M1027/
- MITRE ATT&CK, M1032 Multi-factor Authentication: https://attack.mitre.org/mitigations/M1032/
- Microsoft Learn, 4624(S) An account was successfully logged on: https://learn.microsoft.com/en-us/windows/security/threat-protection/auditing/event-4624
- Ultimate Windows Security, Event ID 4624 (UAC split token): https://www.ultimatewindowssecurity.com/securitylog/encyclopedia/event.aspx?eventid=4624
- NIST SP 800-61 Rev. 3 (April 2025): https://csrc.nist.gov/pubs/sp/800/61/r3/final
- Internal: case INC-20260929-001 and the Day 25, Day 26 and Day 27 reports.